SKALA P282 김민정

SK 주식회사 AX

PRIVACY ON

INTEGRATED PRIVACY PROTECTION SERVICE

SKALA P282 김민정

PRIVACY ON

Painpoint

문제제기

Painpoint

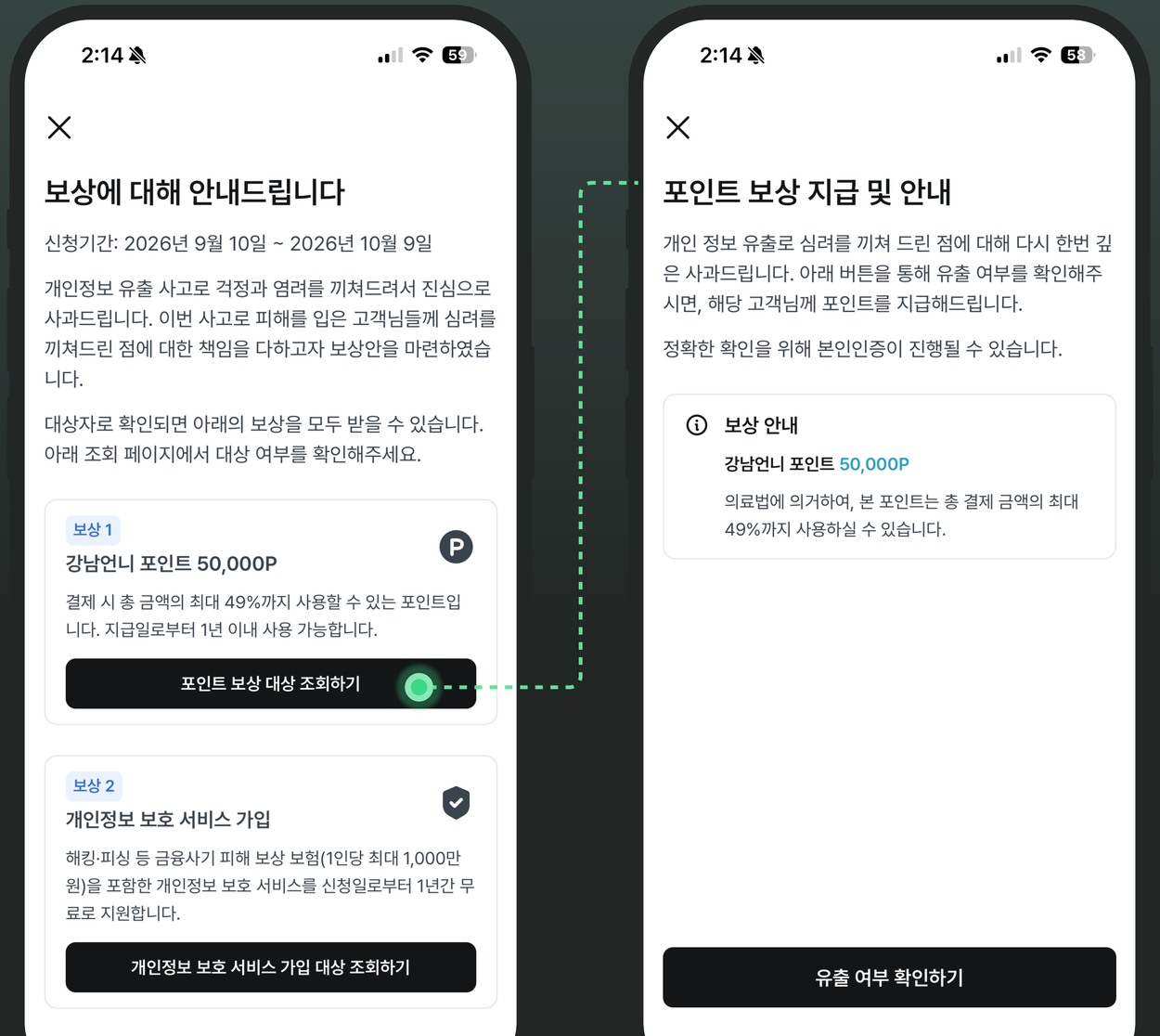
최근 개인 정보 유출 사례

최근 개인 정보 유출 사례의 급증으로 인해 사용자 피해 급증

Painpoint

저 또한 ..
강*** 서비스의 개인정보 유출 피해자

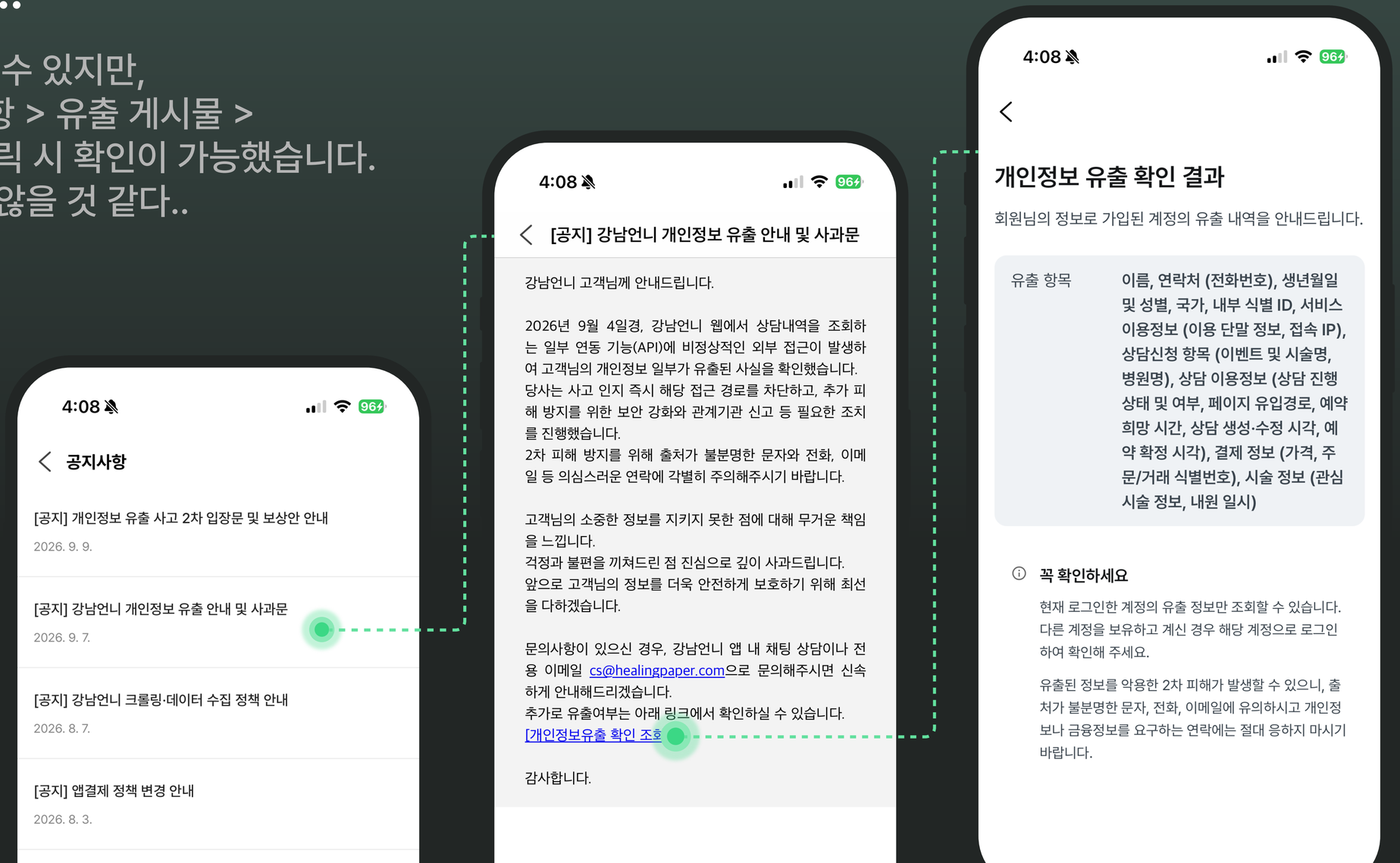
2026년 9월 12일, 강*** 앱에서 개인정보 유출 대상자로 지정됐다는 안내를 받았습니다.



Painpoint

유출 항목이 궁금한데..

보상 안내는 홈에서 쉽게 볼 수 있지만,
나의 유출 데이터는 공지사항 > 유출 게시물 >
개인정보 유출 확인 조회 클릭 시 확인이 가능했습니다.
→ 뎁스가 깊어서 찾아보지 않을 것 같다..



Painpoint

여러분들은 자신의 개인 정보 유출 상태를 잘 알고 계신가요?

어떤 회사에서, 내 어떤 정보가 유출됐는지 알림이 와도,
그냥 넘기고 계시지 않았나요?

Painpoint

유저 인터뷰를 통해 피해자들의 고민을 들어봤어요.

인지하지 못하는 문제

강***에서 내 정보가 유출됐다는
사실조차 모르고 있었어.

서비스 탈퇴

쿠* 유출 사고로
서비스를 탈퇴했어.

Painpoint

User Interview

인지하지 못하는 문제

강***에서 내 정보가 유출됐다는
사실조차 모르고 있었어.

서비스 탈퇴

쿠* 유출 사고로
서비스를 탈퇴했어.

Solution

PRIVACY ON

이제, 나의 개인정보 유출 정보을 한 곳에서 관리

Solution

공개된 개인정보 유출 사고에서 내 정보가 포함되는지 확인하도록 돕는 통합 관리 서비스, PRIVACY ON

Problem 1

뉴스로만 접하는
파편화된 유출 소식

Problem 2

유출돼도 정확히
어떤 정보가 유출됐는지 모름

Problem 3

후속 조치(비밀번호 변경)를
했는지 기억 못함

Solution 1

공개된 유출 사고에서 내가 실제 유출 대상인지 확인하고, 결과를 홈 화면 한 곳에서 관리

Solution 2

사고 상세 화면에서 유출 항목 · 발생일 · 보상 안내 · 대응 가이드를 한눈에 제공

Solution 3

서비스별 비밀번호 변경 체크리스트로 완료 여부를 직접 관리

Solution

공개된 개인정보 유출 사고에서 내 정보가 포함되는지 확인하도록 돕는 통합 관리 서비스, PRIVACY ON

Problem 1

뉴스로만 접하는
파편화된 유출 소식

Problem 2

유출돼도 정확히
어떤 정보가 유출됐는지 모름

Problem 3

후속 조치(비밀번호 변경)를
했는지 기억 못함

Solution 1

공개된 유출 사고에서 내가 실제 유출 대상인지 확인하고, 결과를 홈 화면 한 곳에서 관리

Solution 2

사고 상세 화면에서 유출 항목 · 발생일 · 보상 안내 · 대응 가이드를 한눈에 제공

Solution 3

서비스별 비밀번호 변경 체크 리스트로 완료 여부를 직접 관리

Solution

공개된 개인정보 유출 사고에서 내 정보가 포함되는지 확인하도록 돕는 통합 관리 서비스, PRIVACY ON

Problem 1

뉴스로만 접하는
파편화된 유출 소식

Problem 2

유출돼도 정확히
어떤 정보가 유출됐는지 모름

Problem 3

후속 조치(비밀번호 변경)를
했는지 기억 못함

Solution 1

공개된 유출 사고에서 내가 실제 유출 대상인지 확인하고, 결과를 홈 화면 한 곳에서 관리

Solution 2

사고 상세 화면에서 유출 항목 · 발생일 · 보상 안내 · 대응 가이드를 한눈에 제공

Solution 3

서비스별 비밀번호 변경 체크 리스트로 완료 여부를 직접 관리

시스템 액터 정의

액터 별 제공 기능

시스템 엑터 정의

기업 담당자

플랫폼 관리자

일반 사용자

시스템 엑터 정의

기업 담당자

유출 사고를 등록하고 공지하는 외부 사용자

사고 등록(기본정보→유출 항목→영향 범위→보상정책→
피해 대상 식별값 해시 제출)
등록한 사고 조회 · 반려 시 재제출
사고별 반응 통계 · 보상 지급 현황 관리
관리자 승인 후에만 사용 가능

플랫폼 관리자

신고의 신뢰도를 검증하는 운영자

기업 가입 승인
사고 심사 (승인 / 반려 + 사유)
전사 통계 대시보드
사용자 문의 응대

일반 사용자

내 정보 유출 여부를 확인하고 대응하는 서비스 사용자

홈에서 나의 유출 현황에 대한 정보 확인
전체 사고 탐색·검색
사고별 내 유출 대상 여부 직접 확인
(이메일 해시 대조)
비밀번호 변경 체크리스트

PRIVACY ON

UI 흐름

화면 동작 상세

UI FLOW — 1. 로그인 회원가입

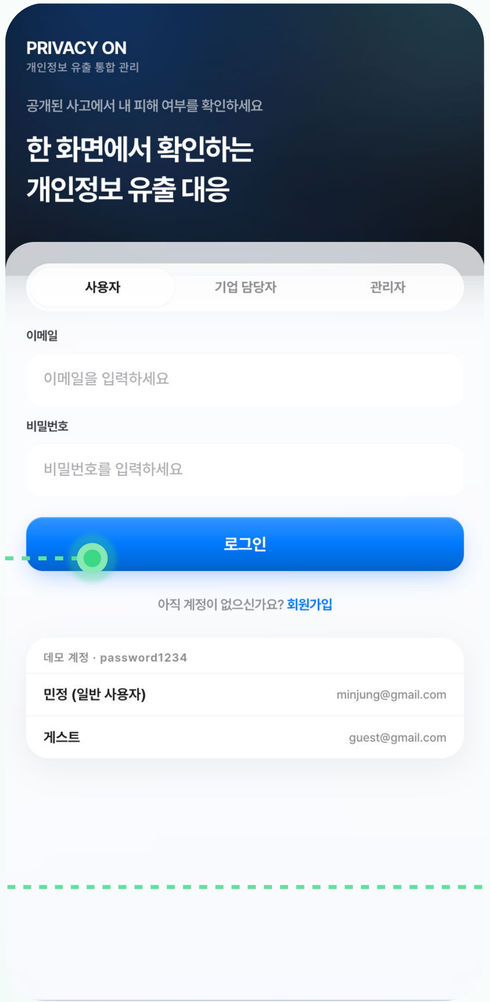
로그인

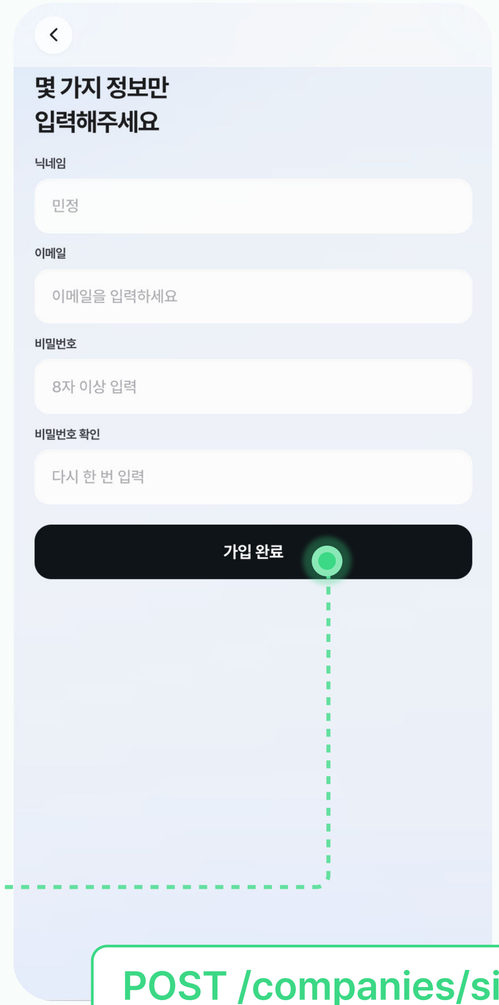
회원가입 - 일반 사용자

회원가입 - 기업 담당자

로그인, 회원가입

역할 세그먼트(사용자/기업 담당자/관리자)
탭으 로 하나의 화면에서 로그인합니다.
기업 담당자는 가입 시 사업자 정보를 입력
하고 승인 대기 상태로 전환





POST /members/login

입력한 이메일과 비밀번호로
일반 사용자 계정을 확인합니다.

POST /members/signup

이메일, 비밀번호, 닉네임을 받아
일반 사용자 계정을 만듭니다.

POST /companies/signup

기업 정보와 담당자 계정을 신청하고 관리자 승인을 기다립니다.

UI FLOW — 2. 홈 화면

일반 사용자

홈 화면에서
나의 개인정보유출 현황을 조회

핵심 기능

GET /members/me/exposure-checks

현재 로그인한 사용자가 사고별로 확인한 유출 대상 여부 결과를 최신순으로 조회합니다.

카드 클릭

유출 사고 카드 클릭

사고 상세 화면으로 화면이 전환됩니다.

UI FLOW — 3. 사고탐색

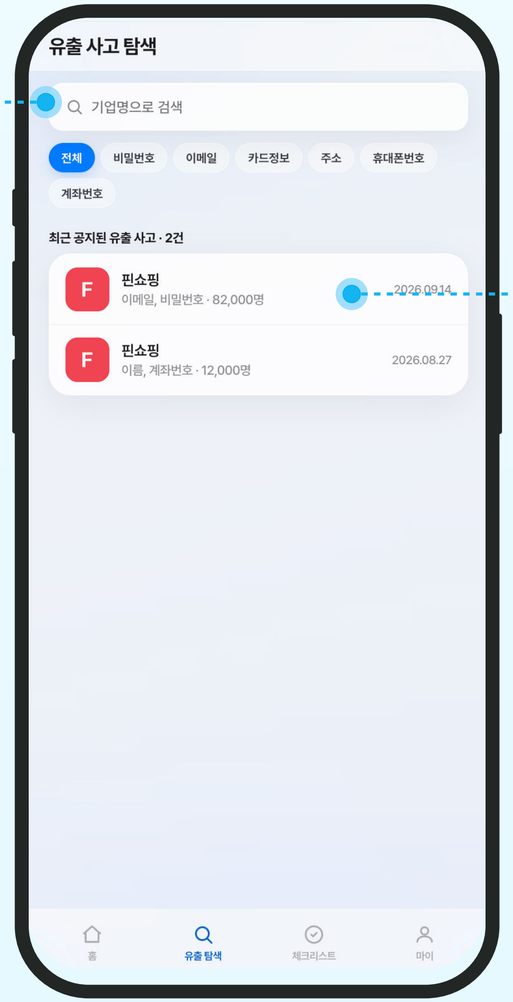
일반 사용자

유출 사건을
검색해볼 수 있습니다.

검색

GET /incidents?
keyword=&category=

모든 이용자가 볼 수 있는 승인 사고만 기업명, 제목, 유출 항목으로 찾습니다.



카드 선택 - 주요 정보 확인 유도

유출 사고 카드 클릭 시

카드 선택 시 화면이 전환되며, 선택한 사고의 자세한 내용, 보상 안내, 대응 방법을 조회합니다.

UI FLOW — 4. 사고 상세

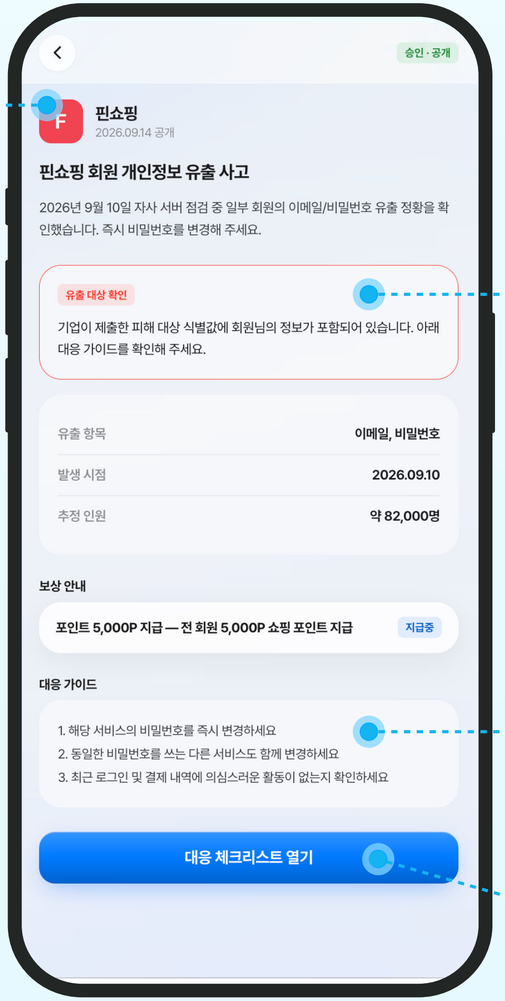
일반 사용자

유출 사건에 대한
상세 정보를 조회할 수 있습니다.

정보 조회

GET /incidents/{incidentId}

어떤 정보가 유출됐는지, 언제 발생했는지, 보상 안내가 있는지 확인합니다.



카드 선택 - 주요 정보 확인 유도

POST /incidents/{incidentId}/exposure-check

확인 이력이 없으면 '내 유출 여부 확인' 버튼 표시 되는데, 그 버튼을 누르면 내 피해 여부를 호출합니다 로그인 이메일 해시를 기업이 제출한 피해 대상 해시와 비교해 결과를 저장합니다.

카드 선택 - 주요 정보 확인 유도

대응 방법 안내

유출 항목에 따라 비밀번호 변경과 이용 내역 확인 같은 기본 대응 방법을 보여줍니다.

클릭 시

비밀번호 체크 화면으로 이동합니다

UI FLOW — 5. 비밀번호 변경 체크

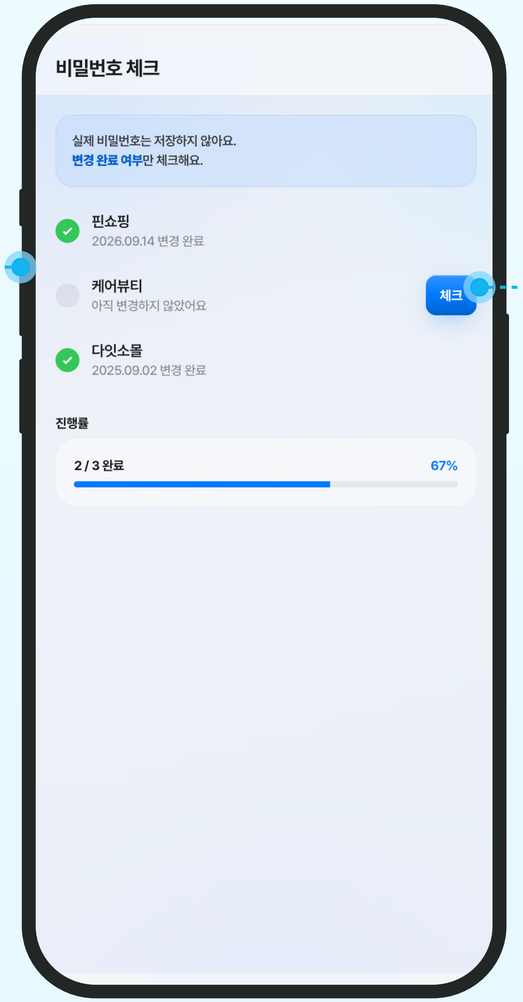
일반 사용자

이 기능은 사용자의 대응을
기억하도록 돕는 기록입니다.
실제 비밀번호 변경 성공을
직접 검증하지는 않습니다.

정보 조회

GET /members/me/password-checks

등록한 서비스별로 변경 완료 여부와
마지막 기록 시각을 조회합니다.



비밀번호 변경 체크

POST /members/me/password-checks

비밀번호 변경 완료를 기록합니다.
사용자가 선택한 서비스의 변경 완료 시각만 저장합니다. 비밀번호 값은 저장하지 않습니다.

UI FLOW — 6. 마이페이지, 1:1 문의

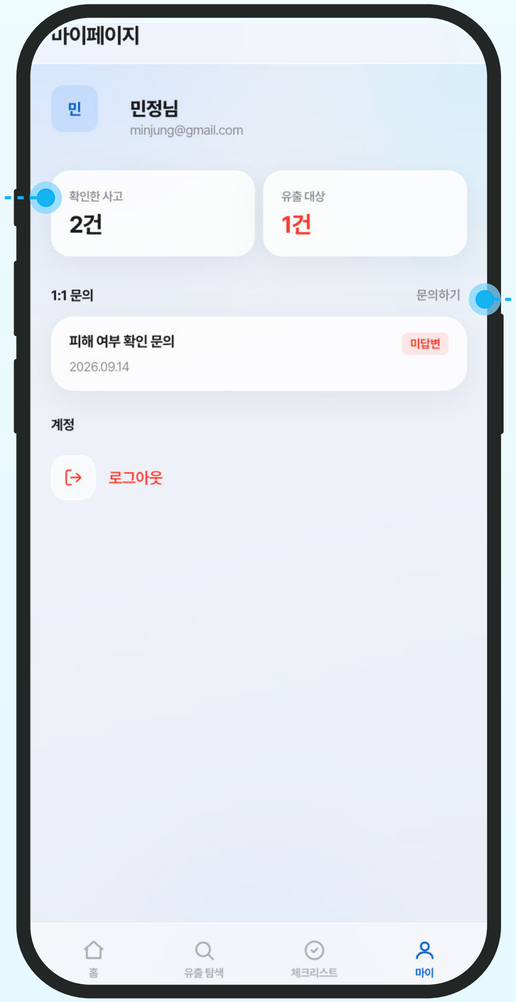
일반 사용자

사용자 정보와,
사용자 문의를 남길 수 있어요.

정보 조회

GET /members/me

현재 로그인한 사용자의 프로필, 피해 확인 이력, 문의 현황을 조회합니다.



문의 내용을 등록

POST /members/me/inquiries

문의하기 버튼을 누르면 입력 폼이 생깁니다.
제목과 내용을 받아 사용자 문의를 접수하고,
관리자가 답변할 수 있게 합니다.

UI FLOW — 7. 등록한 유출사고 목록

기업 담당자

등록한 유출 사고 목록

기업 입장에서 등록한 유출 사고에 대
한 목록을 한 눈에 파악할 수 있어요

GET /companies/me/incidents?status=

현재 로그인한 담당자 회사의 사고만 상태별로 조회합니다.

등록한 유출 사고

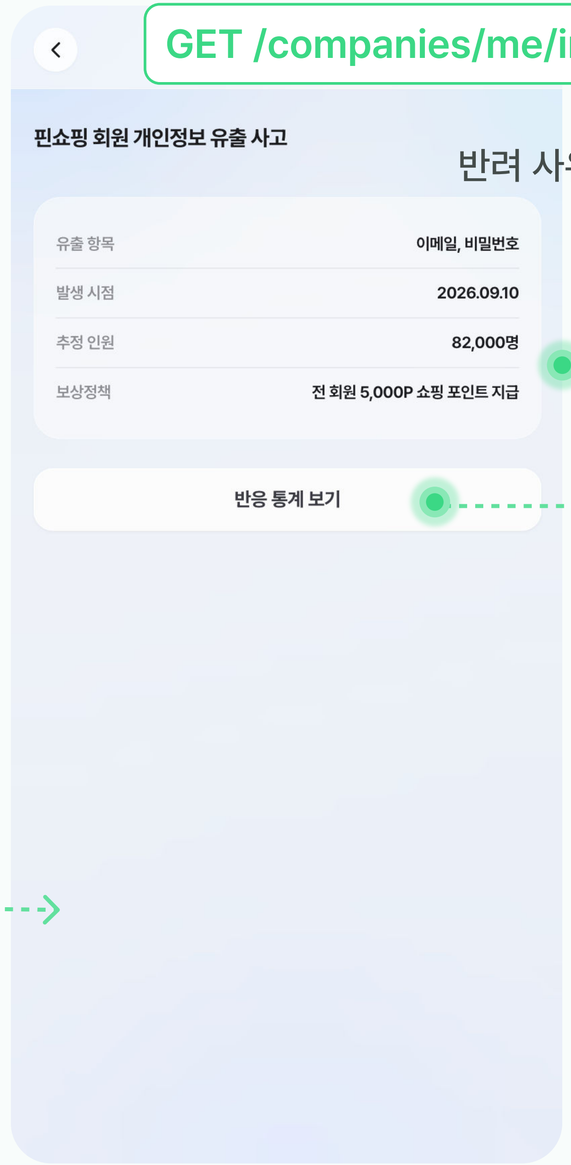
클릭 시

유출 사고에 대한 상세 화면으로 전환됩니다.

유출사고 상세

GET /companies/me/incidents/{incidentId}

선택한 사고의 심사 상태,
반려 사유, 보상정책을 확인합니다.



클릭 시

반응 통계 화면으로 전환

UI FLOW — 8. 유출 사고 등록 단계

기업 담당자

1 단계 : 기본 정보

제목, 사고 개요, 발생 시각을
화면 안에서 임시로 보관합니다.

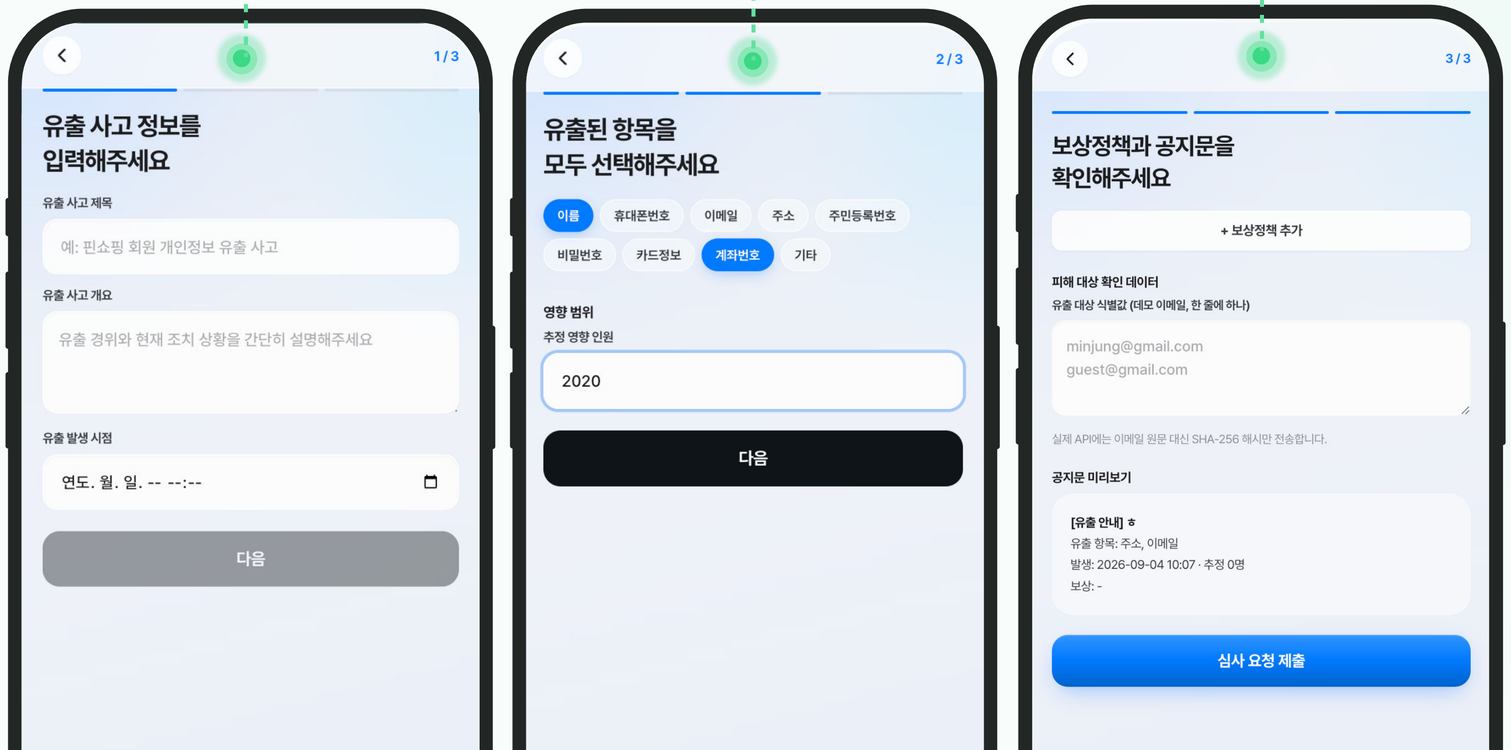
2 단계 : 유출 항목

유출된 정보의 종류를 선택합니다
선택한 항목과 이전 기본정보를 함께 유지한 채
영향 범위와 보상 안내를 입력합니다.

3 단계 : 최종 제출

POST /companies/me/incidents

영향 범위와 보상 안내를 입력합니다
세 단계 입력값을 한 번에 전송하고 사고 상태
를 심사중으로 만듭니다.

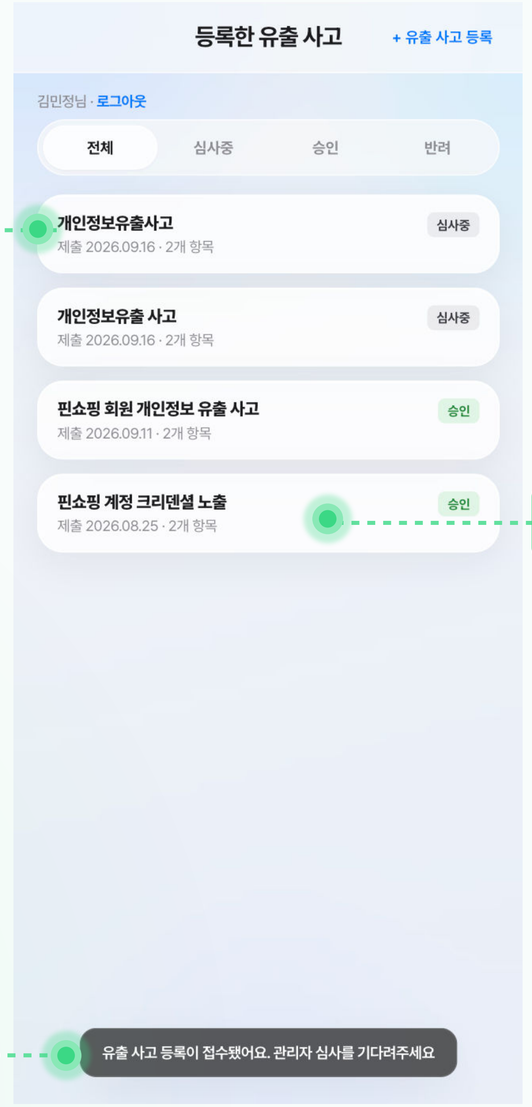


UI FLOW — 9. 등록 후, 유출 사고 목록 재확인

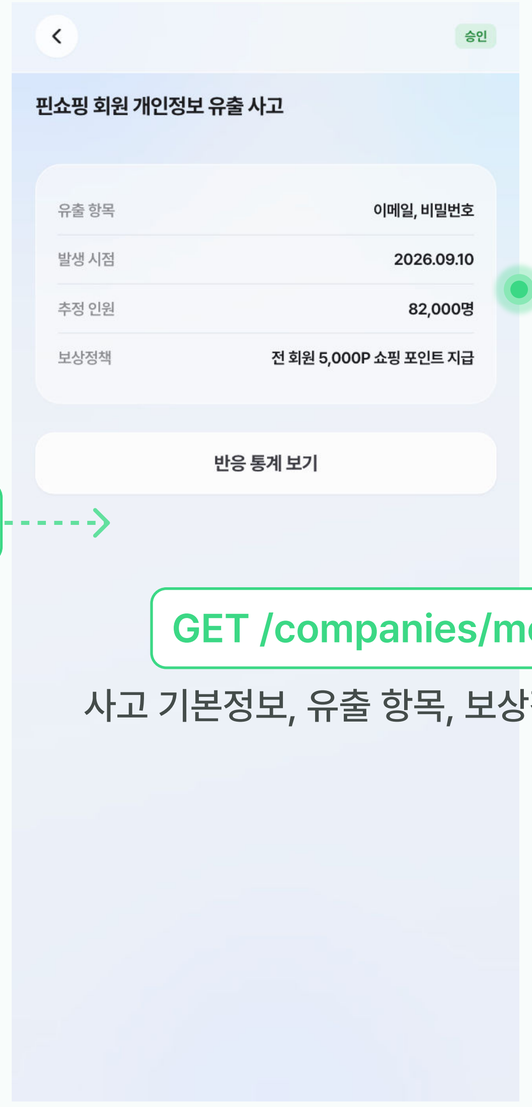
기업 담당자

GET /companies/me/incidents?status=

심사 상태를 다시 조회합니다



클릭 시



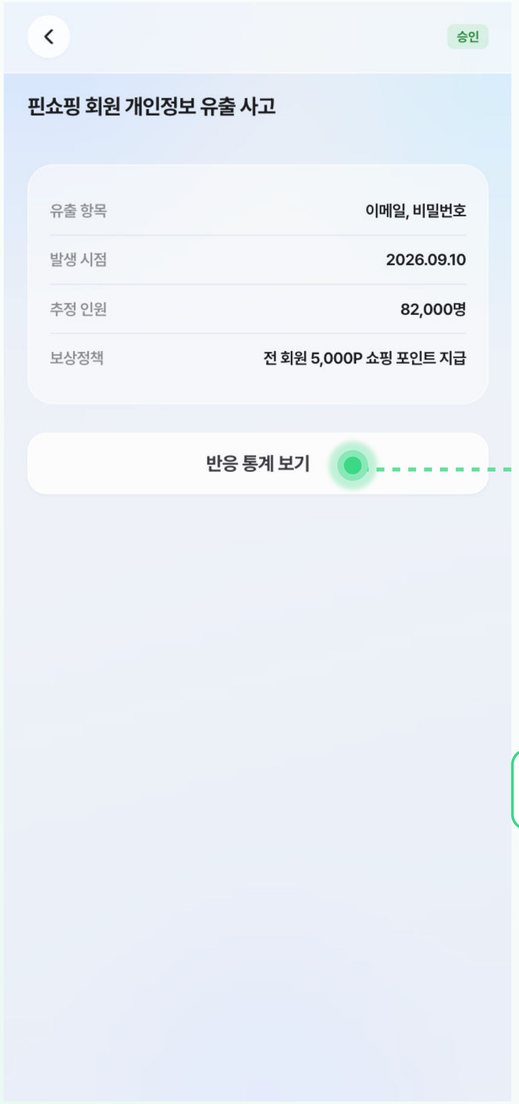
GET /companies/me/incidents/{incidentId}

사고 기본정보, 유출 항목, 보상정책, 심사 결과를 조회합니다.

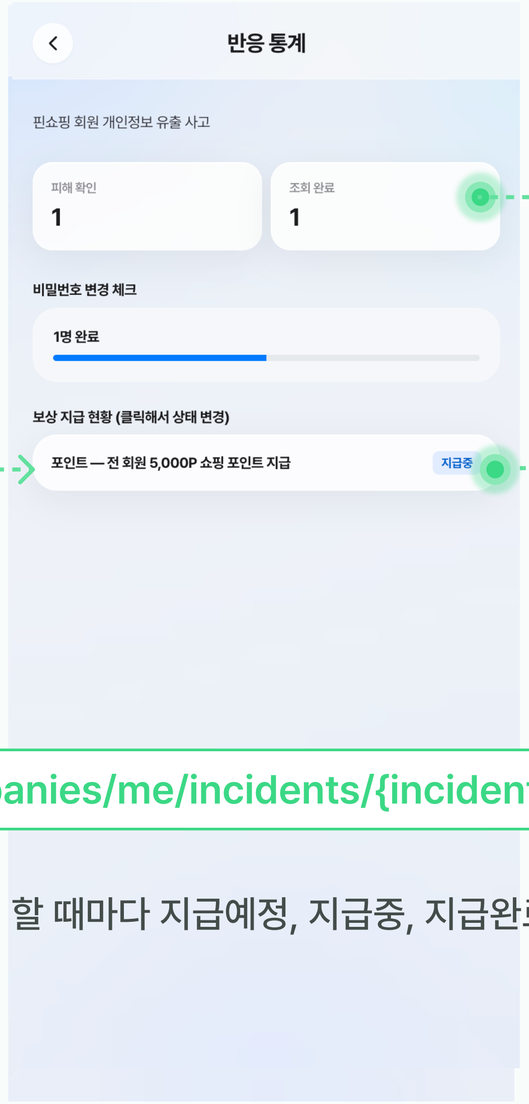
유출 사고 접수 완료 알림

UI FLOW — 10. 사고 반응 통계와 보상 관리

기업 담당자



클릭 시



GET /companies/me/incidents/{incidentId}/stats

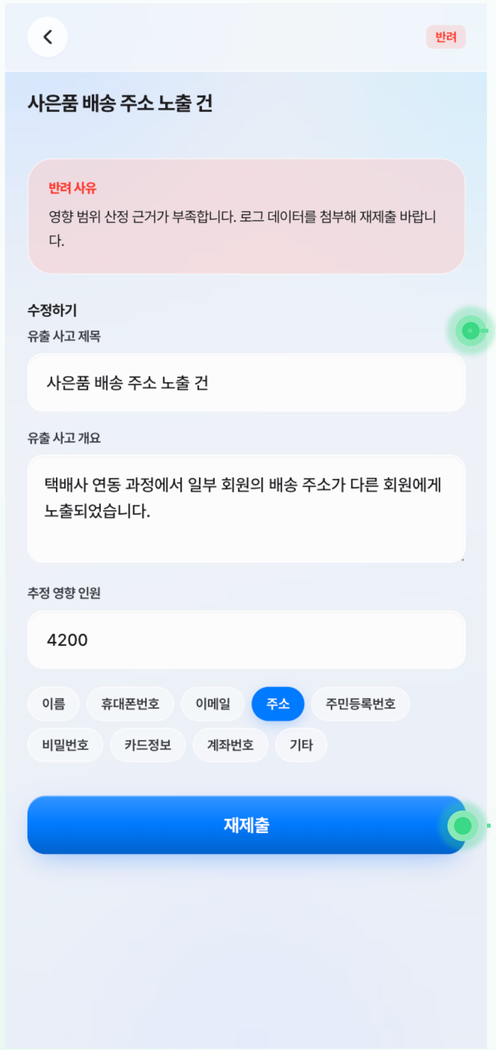
피해 확인 현황을 조회합니다
피해 대상 식별값 수, 확인 완료 수, 유출 대상으로 확인된 사용자 수를 보여줍니다.

PATCH /companies/me/incidents/{incidentId}/compensation-policies/{policyId}

보상정책의 진행 상태를 바꿉니다
클릭 할 때마다 지급예정, 지급중, 지급완료 로 바뀌며, 현재 보상 진행 상태를 저장합니다.

UI FLOW — 11. 반려 사고 수정과 재제출

기업 담당자



GET /companies/me/incidents/{incidentId}

관리자의 반려 사유를 확인합니다
무엇을 보완해야 하는지 확인한 뒤 기존 입력값을 불러옵니다.

클릭 시 → **PUT /companies/me/incidents/{incidentId}**

수정한 내용을 다시 제출합니다
사고 내용을 수정하고 상태를 다시 심사중으로 바꿉니다.

UI FLOW

12. 기업 가입 승인 큐

플랫폼 관리자

GET /admin/companies/pending

승인 대기 기업을 조회합니다
아직 사용 승인을 받지 못한 기업 담당자 계정을 목록으로 봅니다.

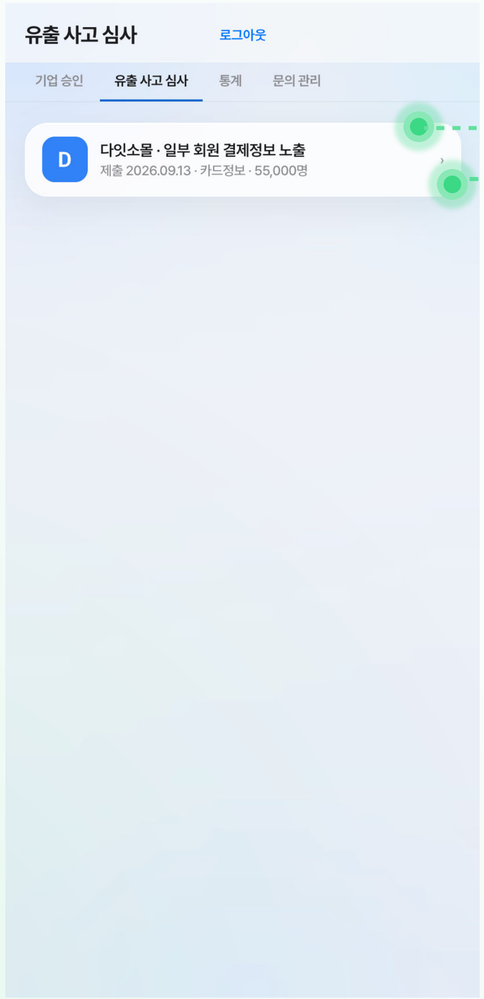
PUT /admin/companies/{companyAccountId}/approve 또는 /reject

기업 계정을 승인하거나 반려합니다
승인하면 사고 등록을 허용합니다. 반려할 때는 사유를 입력합니다.

UI FLOW

13. 유출 사고 심사 큐

플랫폼 관리자



GET /admin/incidents/pending

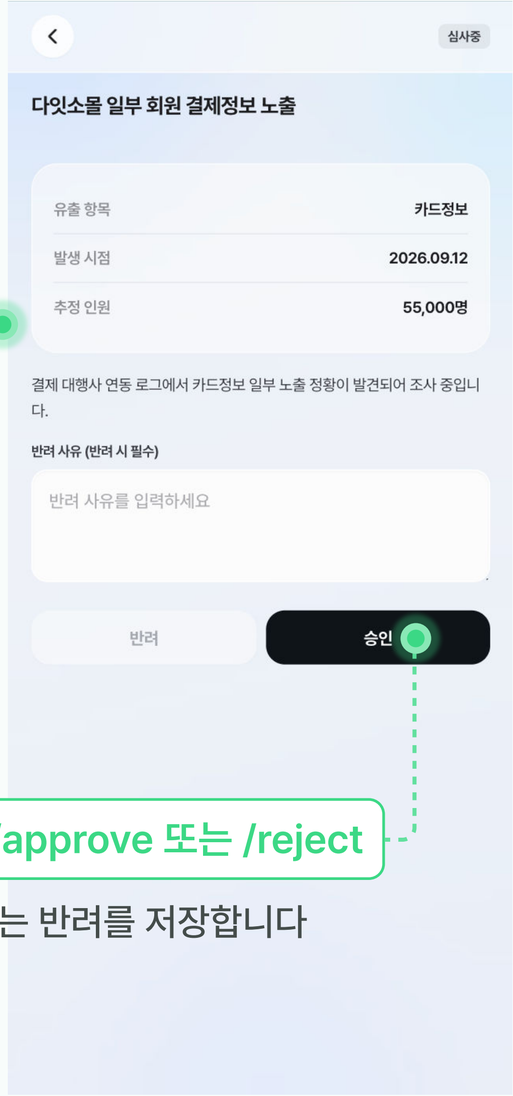
심사 대기 중인 유출 사고를 조회합니다

GET /admin/incidents/{incidentId}

제출한 사고 내용을 검토합니다

클릭 시

클릭한 유출 사고에 대한
상세 화면으로 전환됩니다.

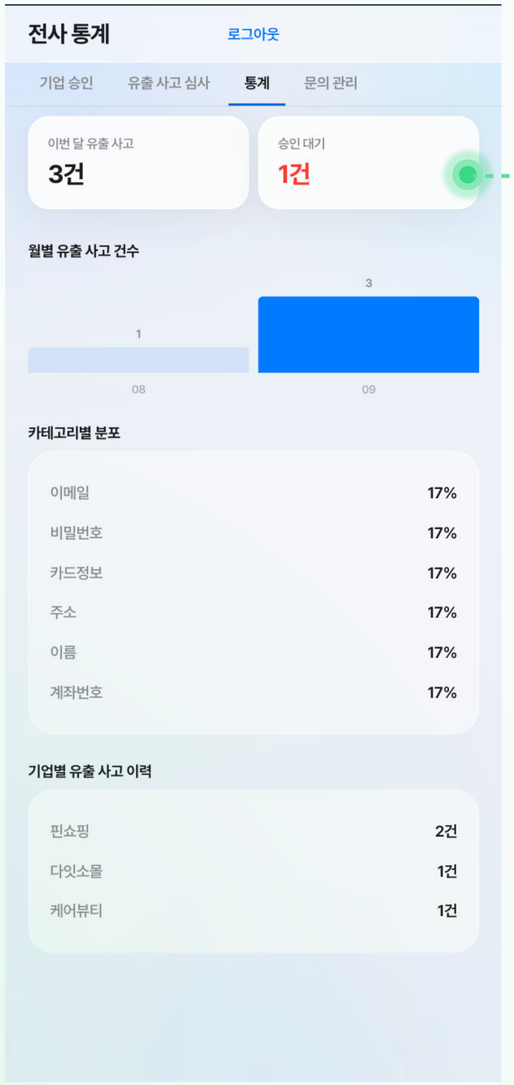


PUT /admin/incidents/{incidentId}/approve 또는 /reject

승인 또는 반려를 저장합니다

UI FLOW — 14. 전사 사고 통계

플랫폼 관리자



GET /admin/stats/incidents

운영 현황을 한 번에 조회합니다
월별 사고 건수, 유출 항목별 건수, 기업별 사고 이력을 조회합니다.

UI FLOW — 15. 사용자 문의 관리

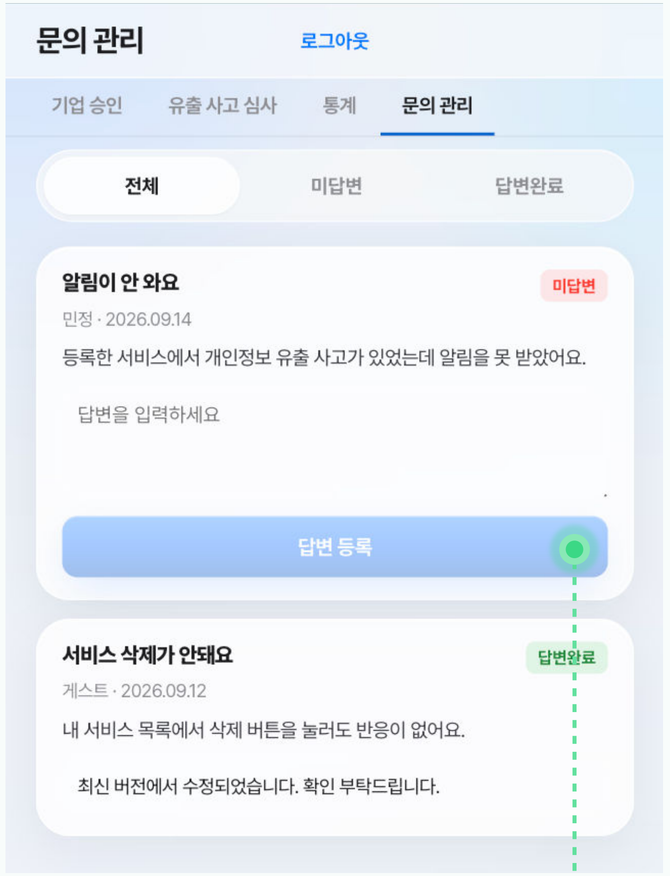
플랫폼 관리자

GET /admin/inquiries

사용자 문의 목록을 조회합니다

답변하기를 누르면
답변 입력창이 생깁니다.

클릭 시



PUT /admin/inquiries/{inquiryId}/answer

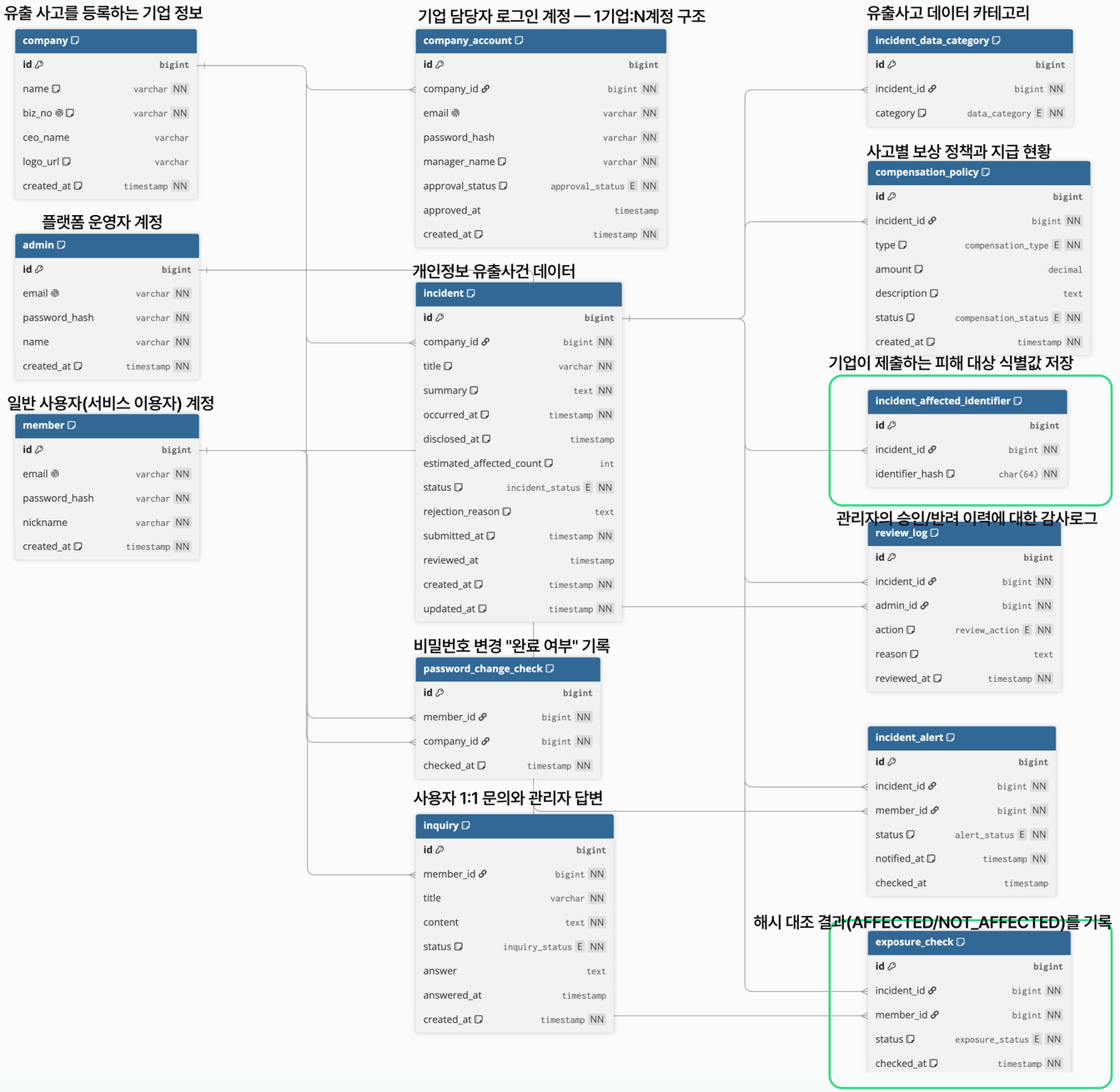
관리자가 작성한 답변과 답변 완료 시각을 저장합니다

PRIVACY ON

데이터 모델 설계

개체(Entity) 정의, 개체 속성(Schema) 및 개체 간 관계 (ERD)

데이터 모델 설계



[정보유출 대상 확인] - 설계 중요 포인트

기업이 제출한 이메일 해시는
incident_affected_identifier에만 저장

① 관리자가 사고를 승인하면
해시가 일치하는 사용자에게 incident_alert가
자동으로 떠서 확인을 유도하고

② 사용자가 직접
"내 유출 여부 확인"을 누르면
그 순간 해시를 대조해 exposure_check에
결과를 기록

PRIVACY ON

API 명세 정의

API 명세 정의

Company / Admin / Member / Incident(Public) 4개 태그로 액터별 그룹화

PRIVACY ON API 1.0.0 OAS 3.0

기업이 등록한 개인정보 유출 사고와 사용자의 개인별 피해 여부 확인을 통합 관리하는 PRIVACY ON API 명세. SKALA AI 웹 서비스 설계 Mini-project (9반 / P282 / 김민정)

- 액터 3분할: 기업 담당자(company) / 일반 사용자(member) / 플랫폼 관리자(admin)
- 문서 내 기업명은 예시를 위한 가상 기업(핀쇼핑, 케어뷰티 등)을 사용
- 본 문서에서는 Security Schemes(인증/인가)를 평가 범위에서 제외하여 기재하지 않음

Servers

https://api.teollim-alim.example.com/v1 - Production (예시)

Company 기업 담당자 - 회원가입/로그인/사고 등록·관리

- POST `/companies/signup` 기업 담당자 회원가입
- POST `/companies/login` 기업 담당자 로그인
- POST `/companies/me/incidents` 사고 등록
- GET `/companies/me/incidents` 등록한 사고 목록 조회
- GET `/companies/me/incidents/{incidentId}` 사고 상세 조회
- PUT `/companies/me/incidents/{incidentId}` 반려된 사고 수정 후 재제출
- GET `/companies/me/incidents/{incidentId}/stats` 사고별 반응 통계 조회
- PATCH `/companies/me/incidents/{incidentId}/compensation-policies/{policyId}` 보상정책 지급 현황 변경

Member 일반 사용자 - 회원가입/로그인, 자동 피해 알림, 사고별 피해 여부 확인, 대응 체크

- POST `/members/signup` 일반 사용자 회원가입
- POST `/members/login` 일반 사용자 로그인
- GET `/members/me` 마이페이지 조회
- GET `/members/me/alerts` 내 유출 사고 목록 조회
- PUT `/members/me/alerts/{alertId}/read` 알림 확인 처리
- GET `/members/me/exposure-checks` 내 유출 여부 확인 이력 조회
- GET `/members/me/password-checks` 비밀번호 변경 체크리스트 조회
- POST `/members/me/password-checks` 비밀번호 변경 체크 등록
- GET `/members/me/inquiries` 내 문의 이력 조회
- POST `/members/me/inquiries` 문의 등록
- POST `/incidents/{incidentId}/exposure-check` 내 정보 유출 여부 확인

API 명세 정의

Company / Admin / Member / Incident(Public) 4개 태그로 액터별 그룹화

Admin 플랫폼 관리자 - 기업 승인, 사고 심사, 통계, 문의 관리

- POST `/admin/login` 관리자 로그인
- GET `/admin/companies/pending` 기업 가입 승인 대기 큐 조회
- PUT `/admin/companies/{companyAccountId}/approve` 기업 가입 승인
- PUT `/admin/companies/{companyAccountId}/reject` 기업 가입 반려
- GET `/admin/incidents/pending` 사고 심사 대기 큐 조회
- GET `/admin/incidents/{incidentId}` 사고 심사 상세 조회
- PUT `/admin/incidents/{incidentId}/approve` 사고 승인
- PUT `/admin/incidents/{incidentId}/reject` 사고 반려
- GET `/admin/stats/incidents` 전사 통계 대시보드 조회
- GET `/admin/inquiries` 사용자 문의 목록 조회
- PUT `/admin/inquiries/{inquiryId}/answer` 문의 답변 등록

Incident (Public) 사용자에게 공개되는 사고 탐색/검색 API

- GET `/incidents` 전체 사고 탐색/검색
- GET `/incidents/{incidentId}` 사고 상세 조회 (공개)

api 명세 정의

기업 담당자 api

Method	Path	Summary	Responses
POST	/companies/signup	기업 담당자 회원가입 — 가입 직후 PENDING, 관리자 승인 후 로그인 가능	400 201 409
POST	/companies/login	기업 담당자 로그인 — APPROVED 계정만 성공 처리	400 200 403 401
POST	/companies/me/incidents	사고 등록 — 기본정보→유출항목→영향범위→보상정책→피해 대상 식별값 해시까지 한 번에 제출	400 201
GET	/companies/me/incidents	등록한 사고 목록 조회 (상태 필터·페이지네이션)	200
GET	/companies/me/incidents/{incidentId}	사고 상세 조회	200 404
PUT	/companies/me/incidents/{incidentId}	반려된 사고 수정 후 재제출 — REJECTED 상태만 가능, 성공 시 PENDING 복귀	400 200 409
GET	/companies/me/incidents/{incidentId}/stats	사고별 반응 통계 — 식별값 제출 수·확인 완료 수·유출대상 확인 수·비밀번호 변경 체크 수	200
PATCH	/companies/me/incidents/{id}/compensation-policies/{policyId}	보상정책 지급 현황 변경	400 200

플랫폼 관리자 api

Method	Path	Summary	Responses
POST	/admin/login	관리자 로그인	400 200 401
GET	/admin/companies/pending	기업 가입 승인 대기 큐 조회	200
PUT	/admin/companies/{companyAccountId}/approve	기업 가입 승인	200
PUT	/admin/companies/{companyAccountId}/reject	기업 가입 반려 (사유 필수)	400 200
GET	/admin/incidents/pending	사고 심사 대기 큐 조회	200
GET	/admin/incidents/{incidentId}	사고 심사 상세 조회 (심사 이력 포함)	200
PUT	/admin/incidents/{incidentId}/approve	사고 승인 — disclosedAt 확정 · **피해 대상 해시가 일치하는 사용자에게만** 알림 생성	200
PUT	/admin/incidents/{incidentId}/reject	사고 반려 (사유 필수)	400 200
GET	/admin/stats/incidents	전사 통계 대시보드 — 월별 건수·카테고리 분포·기업별 이력	200
GET	/admin/inquiries	사용자 문의 목록 조회	200
PUT	/admin/inquiries/{inquiryId}/answer	문의 답변 등록	400 200

일반 사용자 api

Method	Path	Summary	Responses
POST	/members/signup	일반 사용자 회원가입	400 201 409
POST	/members/login	일반 사용자 로그인	400 200 401
GET	/members/me	마이페이지 조회 — 프로필·확인 이력·자동 알림·문의 현황 요약	200
GET	/members/me/alerts	내 유출 사고 목록 조회 — 식별값이 일치해 자동 생성된 알림	200
PUT	/members/me/alerts/{alertId}/read	알림 확인 처리	200
GET	/members/me/exposure-checks	내 유출 여부 확인 이력 조회 — 사고별로 **내가 직접 확인한** 결과를 최신순으로	200
GET	/members/me/password-checks	비밀번호 변경 체크리스트 조회	200
POST	/members/me/password-checks	비밀번호 변경 체크 등록 — 실제 비밀번호 값은 저장하지 않음	400 201
GET	/members/me/inquiries	내 문의 이력 조회	200
POST	/members/me/inquiries	문의 등록	400 201
POST	/incidents/{incidentId}/exposure-check	★ **내 정보 유출 여부 확인** — 이메일을 SHA-256 해시해 기업 제출 해시와 대조 (원문 미전달)	200 404

공통 api

Method	Path	Summary	Responses
GET	/incidents	전체 사고 탐색/검색 — 승인(공개)된 사고만 대상, 기업명/카테고리 필터	200
GET	/incidents/{incidentId}	사고 상세 조회 (공개) — 유출 항목·발생/공지일·보상안내·대응가이드	200 404

고려사항

설계 상의 고민, 다음 단계 개발 시 고려 사항

설계 상 고민 - 예외 시나리오

예외 · 오류 시나리오

기업 계정 로그인 및 서비스 등록 오류 코드와 사용자 안내·시스템 처리 방법

시나리오	처리	사용자 안내 및 시스템 동작
승인 대기(PENDING) 기업 계정으로 로그인	**403**	관리자 승인이 완료되지 않은 계정임을 안내하고 로그인을 차단
이메일/비밀번호 불일치	**401**	사용자·기업·관리자 로그인에 공통 인증 오류 메시지 표시
이미 등록된 이메일 또는 사업자등록번호	**409**	중복 가입을 막고 기존 계정으로 로그인을 안내
REJECTED가 아닌 사고 수정 시도	**409**	반려된 사고만 수정·재제출할 수 있도록 상태를 다시 확인
필수 입력 누락 또는 잘못된 요청	**400**	등록·수정 화면에 입력 오류와 수정할 항목을 안내
존재하지 않거나 권한 없는 사고 조회	**404**	다른 사용자의 정보 노출을 막기 위해 동일한 오류로 처리

다음 단계 개발 시 고려사항

다음 단계 고려사항

이번 설계 범위에서 남겨둔 부분과, 다음 단계에서 검토할 개선 과제

인증/인가 정식 도입

식별 헤더 방식을 JWT/세션 기반 인증으로 전환하
고, Security Schemes를 정식으로 명세에 포함

통계 집계 성능 개선

현재 통계 API는 요청마다 전체 데이터를 집계 — 데이터가 커지면 배치/캐시 집계 테이블 구조로 전환 검토

외부 알림 채널 확장

현재는 인앱 알림(IncidentAlert)만 생성 — 이메일·푸시·문자 등 외부 채널까지 연동 확장 필요